Introduction à l'Ethical hacking

- *. DÉFINITIONS*
- **C'est quoi le piratage (hacking) ?**
- C'est un ensemble de technique utilisées dans le but de compromettre la politique de sécurité d'un système en exploitant ses vulnérabilités afin d'y avoir accès avec une intention malveillante ou pour améliorer la sécurité.
- **Exemple :** vol, divulgation d'informations sensibles, vérification de la robustesse de la sécurité d'un système, etc.


USERNAME
IDENTITY
ACCOUNT
PASSWORD
HACK
BANK
SPY

C’est quoi l’ethical hacking ?

- C’est le fait d’utiliser des outils de piratage combinés avec des techniques et astuces pour tester l’efficacité de la politique de sécurité d’un système, d’identifier ses vulnérabilités afin d’améliorer et de garantir sa sécurité. L’ethical hacker est employé par une organisation afin d’évaluer la politique de sécurité de son système.


PECB Certified
Lead Ethical Hacker

Pourquoi l’ethical hacking ?

- Pour se prémunir contre les hackers face à leurs tentatives d’accès au système
- Pour découvrir des vulnérabilités
- Pour renforcer la sécurité d’une organisation
- Pour garantir la protection des données
- Pour éviter les violations de sécurité
- Pour relever son niveau de connaissance en sécurité

Qui peut être un ethical hacker ?

- Quelqu'un ayant :
- Des Connaissances sur l'environnement des systèmes d'exploitation
- Des Connaissances en réseau
- De l'expertise en informatique
- Des connaissances dans les domaines de la sécurité informatique
- Une Capacité d'apprentissage
- Une Solide éthique de travail
- Une conscience des standards, politiques et lois qui régissent la sécurité informatique.

La cryptographie

Cruptos : Caché.

Graphein : Ecrire

cryptologie==science du secret

- La cryptologie : Mécanisme permettant de camoufler des messages i.e., de le rendre incompréhensible pour quiconque n'est pas autorisé. Elle fait partie d'une ensemble de théories et de techniques liées à la transmission de l'information (théorie des ondes électromagnétiques, théorie du signal, théorie des codes correcteurs d'erreurs, théorie de l'information, théorie de la complexité,...).
- Cryptologie = Cryptographie + Cryptanalyse
- La cryptographie : est l'art de rendre inintelligible, de crypter, de coder, un message pour ceux qui ne sont pas habilités à en prendre connaissance.
- La cryptanalyse : art de "casser" des cryptosystèmes.
- Protocole : description de l'ensemble des données nécessaires pour mettre en place le mécanisme de cryptographie : ensemble des messages clairs, des messages cryptés, des clés possibles, des transformations.
- Signature s : Chaine de caractères associées à un message donné (et aussi possiblement à une entité) et le caractérisant

Le chiffrement, noté Ek , est l’action de chiffrer un message en clair, noté M, en un message chiffré, noté C, et cela de façon à ce qu’il soit impossible de retrouver le message en clair à partir du message chiffré sans la clé ;

cette clé s’appelle la clé secrète et elle est unique ;

l’action inverse du chiffrement est le déchiffrement. Cette action s’effectue uniquement en possession de la clé secrète ;

le déchiffrement d’un message chiffré sans la clé secrète s’appelle le décryptage ;

un système de chiffrement s’appelle un cryptosystème ;

un cryptographe est une personne qui conçoit des cryptosystèmes ;

un cryptanaliste est une personne qui tente de casser les cryptosystèmes.

D’AUTRES CONCEPTS DE LA CRYPTOGRAPHY

. Protection du trafic réseau traversant l'internet grâce à des méthodes cryptographiques.

. En réseau, la cryptographie implique le processus de cryptage et de décryptage

. la cryptographie est l'étude et la pratique de la dissimulation des données et des informations

. La cryptographie est l'art, l'étude, la science qui consiste à rendre les données impossibles à lire.

. Les algorithmes de cryptographie partent d'un texte en clair et le brouillent pour le rendre illisible

Termes de cryptographie et de chiffrement à connaître



Cryptographie: la pratique de l'écriture et de la résolution de codes.

Clé: une chaîne secrète de caractères.

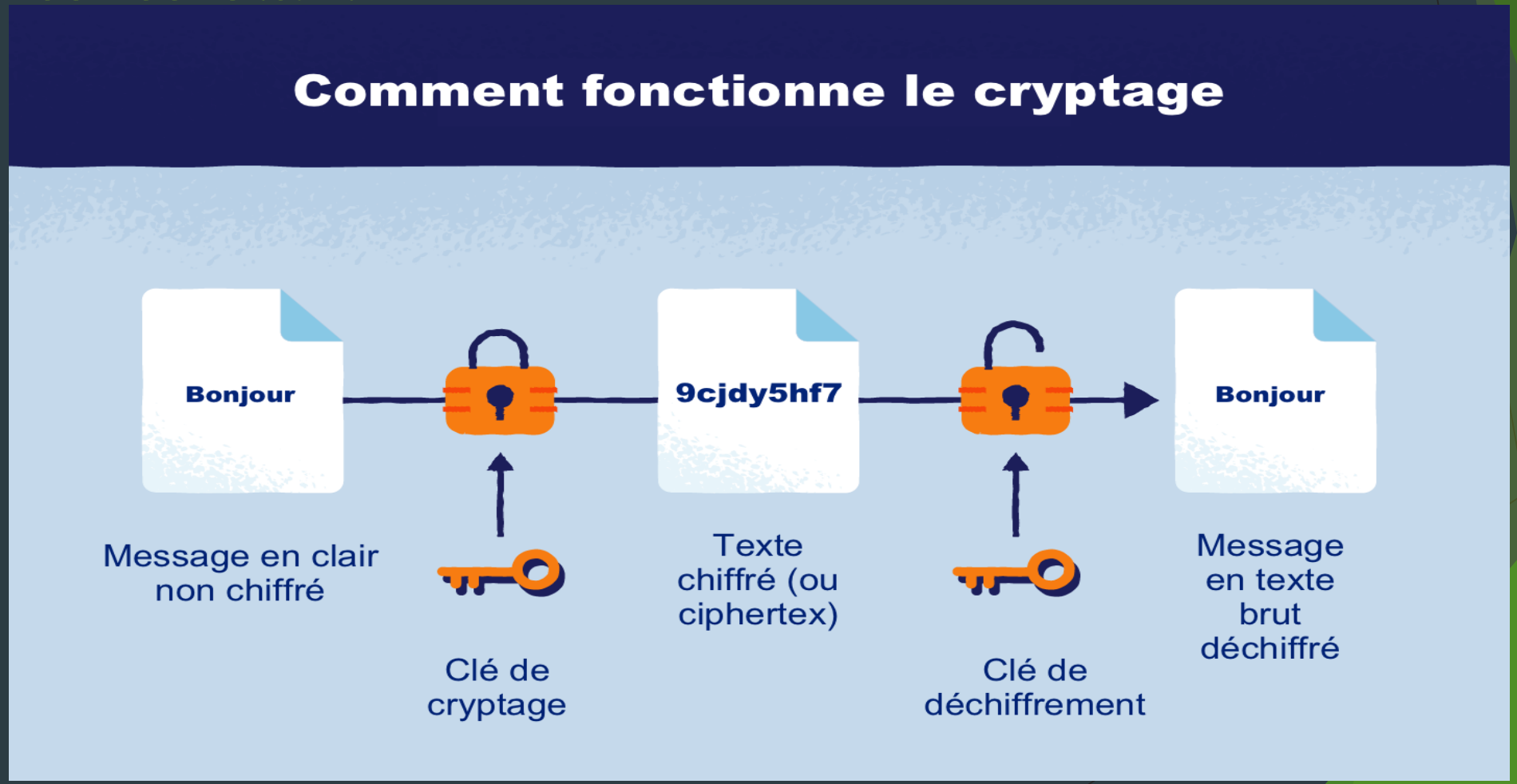
Cryptage: le processus mathématique de création et de partage d'un message codé.

Algorithme de chiffrement: ensemble d'algorithmes qui réalisent le chiffrement.

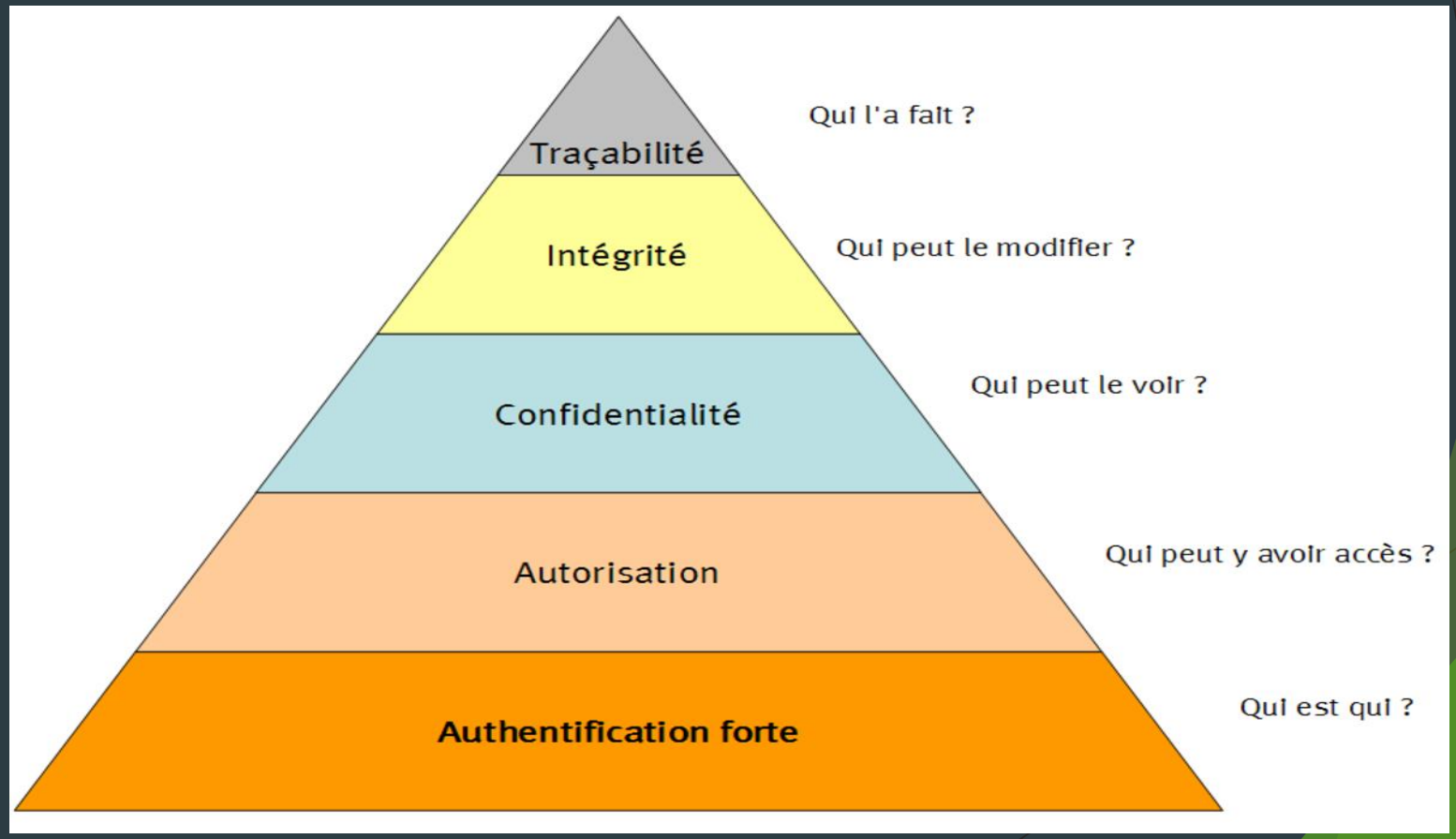
Ciphertext: la forme illisible d'un message codé.

Texte brut: le message décodé.

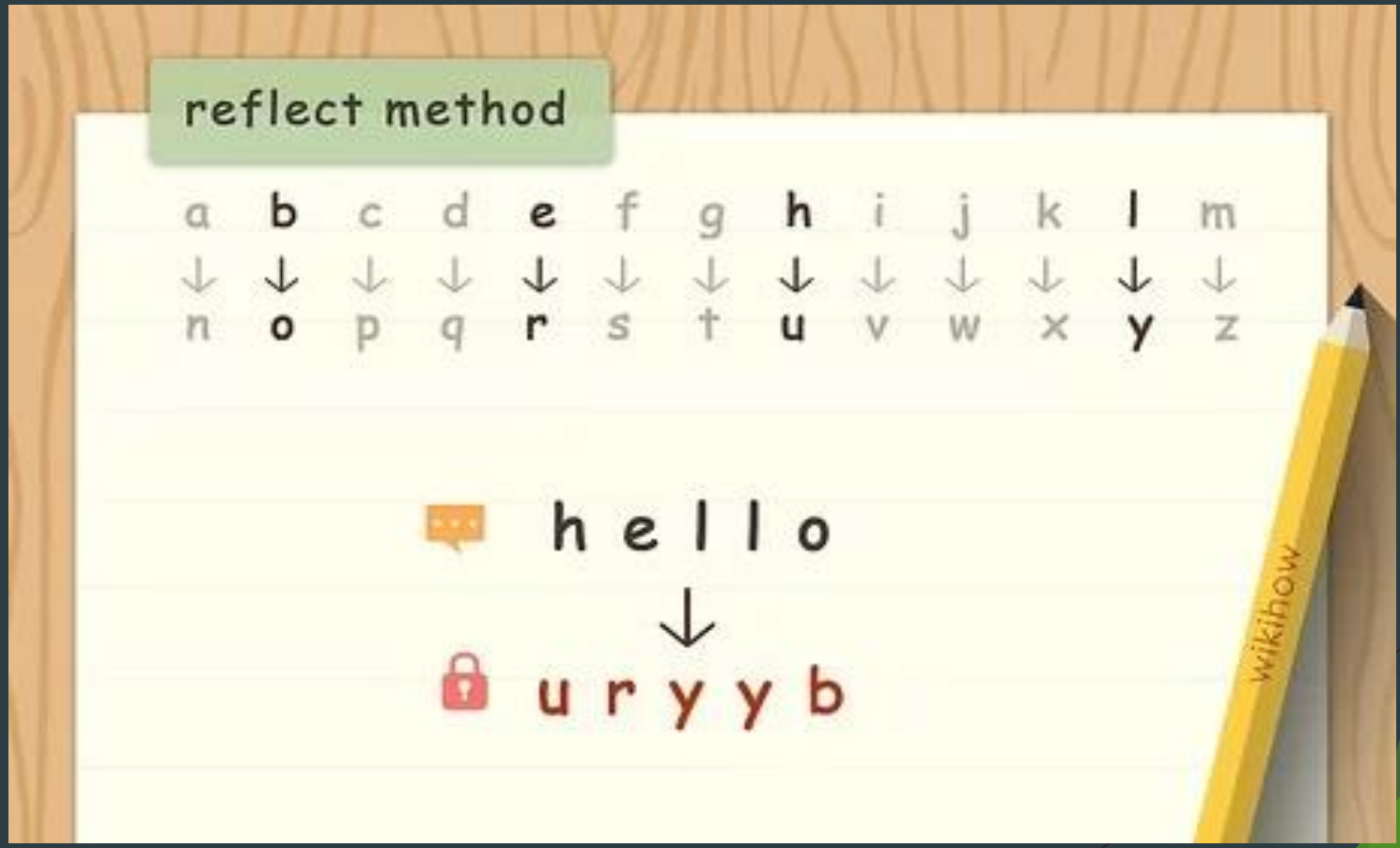
L'algorithme de chiffrement spécifie comment le texte chiffré peut être déchiffré en texte clair.



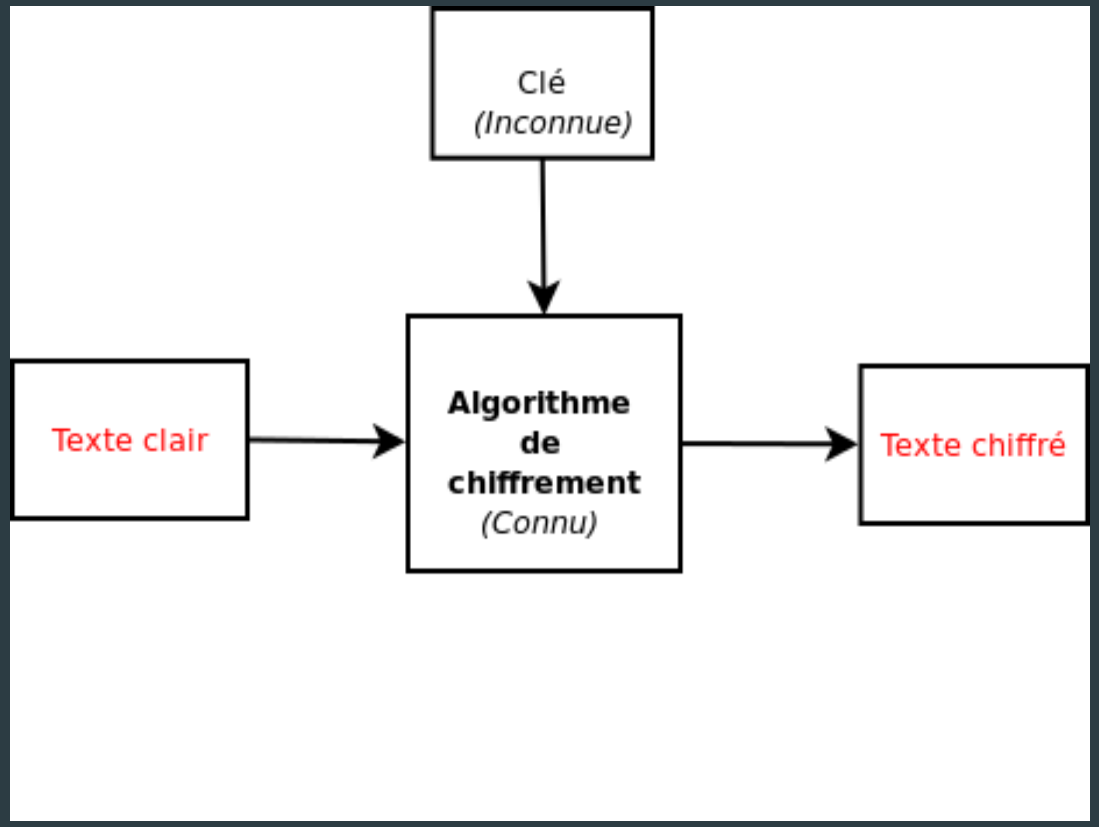
La cryptographie est un élément essentiel pour assurer la confidentialité, l'intégrité et l'authentification.

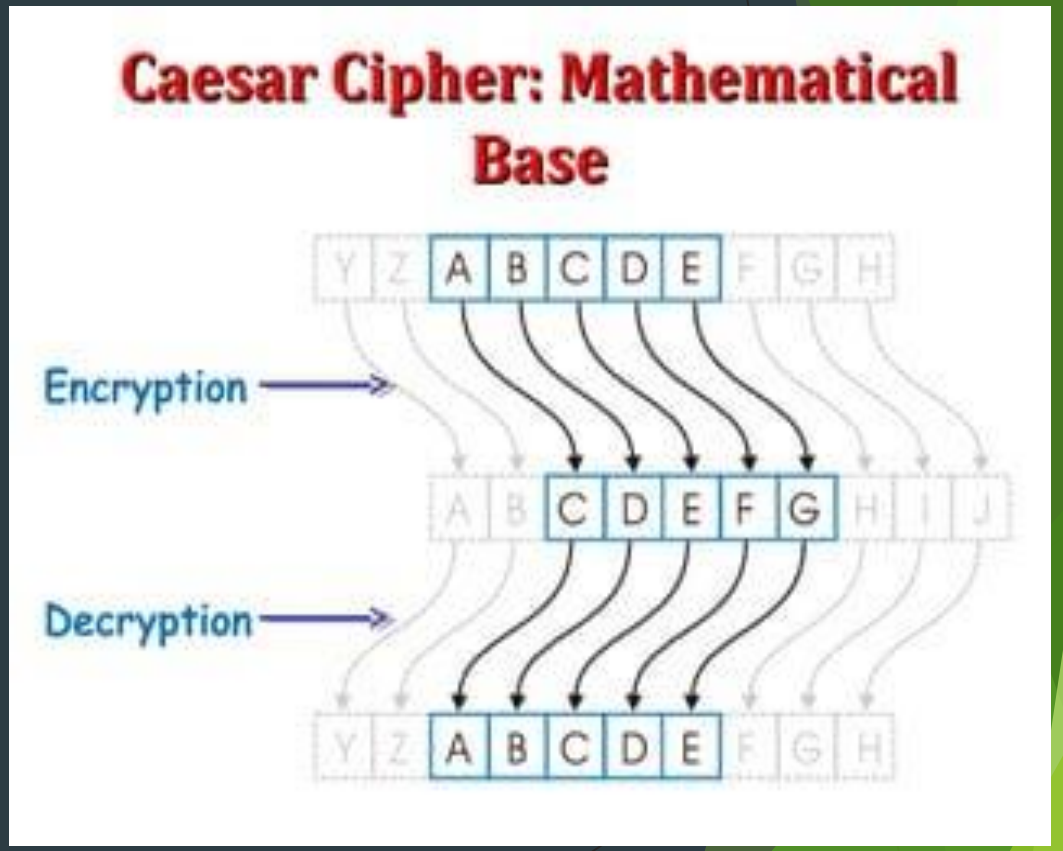


La cryptographie est un moyen et une méthode permettant de garder secrets les messages et autres données.



L'algorithme de chiffrement Ceasar est l'un des algorithmes de chiffrement les plus simples





Dans cet algorithme de César, chaque caractère alphabétique du texte en clair est remplacé.

CRYPTOGRAPHY



PLAINTEXT (texte en clair)

l'information sous sa forme originale ou les données lisibles dites en clair

C’est l’information avant le chiffrement



ENCRYPTION

le processus de transformation/Conversion du texte clair en texte chiffré est appelé chiffrement

le processus de cryptage est la traduction de données ou d'informations en un code secret

le cryptage est une fonction bidirectionnelle, les données cryptées peuvent être décryptées à l'aide d'une clé appropriée

Le processus de chiffrement

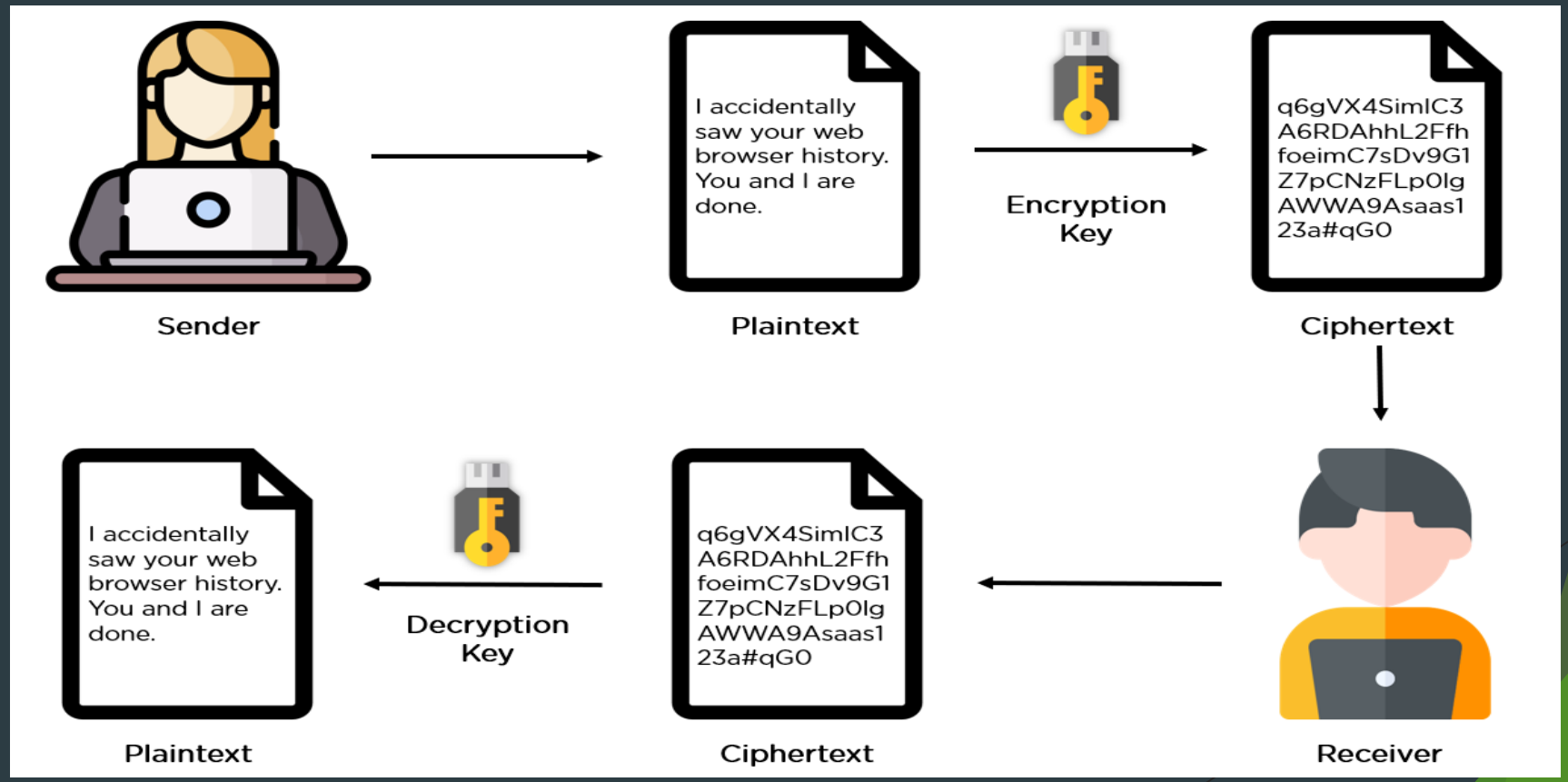
Le role principal du chiffrement est la protection de l’information contre les personnes non authorisées

Le processus de cryptage nécessite un algorithme appelé chiffrement et une clé secrète.

DECRYPTION

le processus de transformation du texte chiffré en texte clair est appelé décryptage

le processus de conversion du texte chiffré en texte clair original est le décryptage



SYMMETRIC AND ASYMMETRIC ENCRYPTION

En cryptographie, le « chiffrement symétrique » utilise une seule clé partagée pour chiffrer et déchiffrer les données, tandis que le « chiffrement asymétrique » (également appelé cryptographie à clé publique) utilise une paire de clés mathématiquement liées - une clé publique pour le chiffrement et une clé privée pour le déchiffrement, permettant à quiconque de chiffrer les données, mais uniquement au destinataire prévu de les déchiffrer à l'aide de sa clé privée ;

essentiellement, le chiffrement symétrique est plus rapide mais nécessite une distribution sécurisée des clés, tandis que le chiffrement asymétrique est plus lent mais gère l'échange de clés de manière plus sûre.

Symmetric Encryption



ONE SESSION KEY

VS

Asymmetric Encryption



TWO DIFFERENT SESSION KEYS

Le monde numérique d'aujourd'hui considère les données comme l'une de ses possessions les plus vitales. Malheureusement, si les technologies avancées ont apporté le luxe à notre mode de vie, elles posent également des menaces qui peuvent conduire à des incidents redoutables. Les cyberattaques et les cybercrimes sont devenus très répandus dans les scénarios numériques modernes.

Par conséquent, pour protéger nos données cruciales contre les activités frauduleuses, le cryptage est l'une des principales clés. Lorsque l'on utilise le mot « cryptage », on entend souvent parler de cryptage symétrique et de cryptage asymétrique. En fait, il s'agit dans les deux cas de techniques de cryptage, mais avec des méthodologies très différentes.

Symmetric Encryption examples

Advanced Encryption Standard (AES)

Le cryptage AES est l'une des normes de cryptage les plus courantes utilisées dans les réseaux internet. Il utilise des algorithmes de chiffrement par blocs de 128, 192 ou 256 bits pour chiffrer et déchiffrer les données. La procédure de cryptage de l'AES est si complexe qu'il est pratiquement impossible de décrypter cette technique.

Data Encryption Standard (DES)

- DES, ou maintenant le National Institute of Standards and Technology (NIST), est l'un des plus anciens algorithmes de cryptage. Cet algorithme décompose les données en blocs de 64 bits. Toutefois, compte tenu de la technologie actuelle, il est plus facile de casser cette méthode de cryptage, qui n'est donc utilisée que par quelques réseaux privés.

Transport Layer Security (TLS) or SSL

- You might have heard the term TLS/SSL many times in your browser. It is a network protocol used to build a secure connection with the server-side. When a user accesses a server, symmetric keys are generated to encrypt and decrypt the data. So that it can be securely shared between the client and the server in that particular session.

International Data Encryption Algorithm (IDEA)

- IDEA is an open and free block-cipher algorithm which was first introduced in the 90’s as a replacement to DES. However, as AES came into existence and turned out to be more efficient, IDEA did not succeed much and remained useful only for research and unofficial purposes.

Benefits of Symmetric Cryptography

- Traitement rapide: La technique de cryptage symétrique utilise des longueurs de clés plus courtes que le cryptage asymétrique, ce qui permet une exécution beaucoup plus rapide.

- Sécurité accrue: Les algorithmes de cryptage symétrique tels que l'AES sont hautement sécurisés et presque impossibles à décrypter.

- Capacité à traiter des fichiers volumineux : L'un des principaux avantages du cryptage symétrique est qu'il permet de traiter plus facilement et plus rapidement des fichiers de grande taille.

Disadvantages of Symmetric Encryption

- Méthode non sécurisée de distribution des clés: Dans cette méthode, un canal non sécurisé compromet la sécurité du processus en transmettant les clés.

- Pas de signature numérique: Les signatures numériques garantissent que le message provient d'une source sûre. Malheureusement, le chiffrement symétrique ne dispose d'aucune méthode pour activer les signatures numériques.

What is Asymmetric Encryption?

- Contrairement au cryptage symétrique, le cryptage asymétrique est un processus dans lequel les données sont cryptées à l'aide d'une clé et décryptées à l'aide d'une autre. Le processus implique donc l'utilisation de deux clés.

- Il est également connu sous le nom de cryptographie à clé publique. Cette forme de cryptage est plus sûre que le cryptage symétrique. Cependant, il est nécessaire de se souvenir de deux jeux de clés pour mettre en œuvre correctement cette technique.

How does Asymmetric Encryption Works?

- Par rapport au cryptage symétrique, la technique de cryptage asymétrique nécessite deux jeux de clés pour l'ensemble du processus. Cette technique implique l'utilisation d'une clé privée et d'une clé publique.

- L'expéditeur convertit le texte en clair en texte chiffré à l'aide de la cryptographie à clé publique. Une fois les données arrivées à destination, le destinataire décrypte le même fichier de données à l'aide de ses clés privées. Les données sont ramenées à leur forme originale en texte clair sans qu'aucune information ne soit volée.

Asymmetric Encryption Examples

- **Rivest Shamir Adleman (RSA)**

RSA est l'un des principaux exemples de cette technique de cryptage. Il génère une clé publique pour la partie cryptage en multipliant deux nombres premiers aléatoires de grande taille. Il génère également la clé privée nécessaire au décryptage des données à partir des mêmes nombres premiers.

Digital Signature Standard (DSS)

- Principalement utilisé pour les signatures numériques, le DSS est généralement associé à l'algorithme de signature numérique (DSA). L'expéditeur utilise sa clé privée pour signer numériquement un message, et le destinataire utilise la clé publique correspondante de l'expéditeur pour confirmer cette signature et recevoir le fichier crypté.

Elliptical Curve Cryptography (ECC)

- La cryptographie à courbes elliptiques (ECC) est une alternative au RSA qui utilise une petite taille de clé mathématique à courbes elliptiques pour le processus de cryptage des données. Cette technique algorithmique est extrêmement populaire en raison de son utilisation dans les crypto-monnaies. En général, l'ECC est beaucoup plus rapide que le RSA.

The Diffie-Hellman Exchange Method

- Cette méthode est extrêmement importante dans l'histoire du cryptage. Il s'agit d'une méthode d'échange de clés qui permet aux deux parties de partager leurs clés sans interaction physique. Avant cette méthode, l'expéditeur et le destinataire devaient se rencontrer pour échanger physiquement leurs clés.

Benefits of Asymmetric Cryptography

- **No Need for Key Distribution**
- L'un des principaux avantages de cette technique est qu'elle élimine le processus de distribution des clés. Les utilisateurs n'ont pas besoin d'envoyer les clés publiques et privées par l'intermédiaire de serveurs de clés publiques, qui représentent généralement une menace plus élevée.

- Digital Signature
- Le chiffrement asymétrique a introduit les signatures numériques dans le monde. Il permet aux utilisateurs de signer numériquement le message avec leur clé privée et de vérifier l'authentification du fichier généré.

- **Higher Security than Symmetric Encryption**
- This method of encryption is more complex due to the use of two keys, making it safer. It uses one key for the encryption and the other for the decryption of files.

Disadvantages of Asymmetric Encryption

- Faible vitesse de traitement
- Le processus étant compliqué et utilisant des clés de grande taille, le traitement des fichiers avec cette méthode prend plus de temps.

- Pas de récupération des données en cas de perte de la clé
- L'un des grands problèmes qui menacent l'utilisation de cette technique de cryptage est que si un utilisateur perd sa clé privée, il n'y a pas d'autre moyen de décrypter le message.

HASH: assurer l’intégralité des données

Un algorithme de hachage est une fonction mathématique qui brouille les données et les rend illisibles.

Les algorithmes de hachage sont des programmes à sens unique, de sorte que le texte ne peut pas être débrouillé et décodé par quelqu'un d'autre. Et c'est là tout l'intérêt. Le hachage protège les données au repos, de sorte que même si quelqu'un accède à votre serveur, les éléments qui y sont stockés restent illisibles.

Le hachage peut également vous aider à prouver que les données ne sont pas ajustées ou modifiées une fois que l'auteur en a terminé avec elles. Enfin, certaines personnes utilisent le hachage pour donner un sens à des masses de données.

LES 5 ETAPES D’UNPIRATAGES

- Les cinq étapes d'un piratage informatique sont : la reconnaissance (collecte d'informations), le balayage (identification des vulnérabilités), l'accès (exploitation des vulnérabilités), le maintien de l'accès (sécurisation de l'accès persistant) et l'effacement des traces (dissimulation de leur présence).

LES 5 ETAPES D’UNPIRATAGES

- Les cinq étapes d'un piratage informatique sont : la reconnaissance (collecte d'informations), le balayage (identification des vulnérabilités), l'accès (exploitation des vulnérabilités), le maintien de l'accès (sécurisation de l'accès persistant) et l'effacement des traces (dissimulation de leur présence).

5 Phases of Ethical Hacking

1. Reconnaissance/ Footprinting



2. Scanning



3. Gaining Access



4. Maintaining Access



5. Clearing Tracks



1-Reconnaissance:

- This is the initial phase where attackers gather information about the target system or network, including its architecture, technologies, and potential vulnerabilities.

- Dans le contexte du piratage informatique ou des tests de pénétration, la reconnaissance est l'étape initiale au cours de laquelle les attaquants recueillent des informations sur une cible avant de lancer une attaque réelle. L'objectif est de collecter autant d'informations que possible sans interagir directement avec la cible, afin d'identifier les vulnérabilités potentielles et de planifier une attaque plus efficace.

- La reconnaissance est souvent divisée en deux types principaux

How Hackers Perform Reconnaissance



1. Identify the Scope of the Target Network
2. Locate Open Ports and Access Points
3. Identify the Services on the Ports
4. Map the Entire Network
5. Avoid Detection the Whole Time

eSecurity Planet

1. Passive Reconnaissance:

Objectif : Recueillir des informations sans interagir directement avec le système cible.

Méthodes utilisées :

Recherche Whois : Utilisation d'outils tels que whois pour vérifier les détails de l'enregistrement du domaine, la propriété, la plage d'adresses IP, etc.

Interrogation DNS : Interrogation des enregistrements DNS pour recueillir des informations sur les sous-domaines et les adresses IP associées.

Informations accessibles au public : Recherche d'informations sur le site web, les médias sociaux, les offres d'emploi ou d'autres données publiques de la cible.

Google Dorking : Utilisation d'opérateurs de recherche avancés sur Google pour localiser des fichiers sensibles, des bases de données ou d'autres données publiques.

- Shodan : recherche de dispositifs ou de serveurs connectés à l'internet et recherche de systèmes mal configurés ou de dispositifs susceptibles d'être vulnérables.

- Analyse du trafic réseau : Surveillance des communications publiques telles que les courriels, les articles de presse ou les communiqués de presse afin de recueillir des informations sur l'infrastructure interne ou les employés.

2. Active Reconnaissance:

- Objectif : interagir directement avec le système cible pour recueillir des informations plus détaillées.
- Méthodes :
- Analyse des ports : Des outils tels que nmap sont utilisés pour identifier les ports ouverts sur une machine cible. Les ports ouverts peuvent indiquer quels services sont en cours d'exécution, ce qui peut révéler des vulnérabilités.
- Empreinte digitale des services : Identification de la version exacte des services fonctionnant sur les ports ouverts afin de détecter les vulnérabilités connues (par exemple, à l'aide de nmap ou de Banner Grabbing).

- Cartographie du réseau : Trouver d'autres systèmes sur le même réseau qui pourraient être des cibles potentielles ou offrir des points d'entrée.

- Analyse des vulnérabilités : Utilisation d'outils tels que Nessus ou OpenVAS pour rechercher les vulnérabilités connues dans les systèmes ou les services.
- Ingénierie sociale : Interaction directe avec les employés ou les utilisateurs de l'organisation cible pour obtenir des informations sensibles (par exemple, par le biais de l'hameçonnage).

Reconnaissance Tools:

- Voici quelques outils populaires utilisés pour la reconnaissance dans le cadre du piratage éthique et des tests de pénétration :

- Nmap : Pour le balayage des ports et la découverte des services.

- Wireshark : Pour l'analyse des paquets du réseau.

- Maltego : Pour la cartographie et la visualisation des relations entre différentes entités (par exemple, domaines, IP, courriels).

- TheHarvester : Pour collecter des courriels, des sous-domaines et d'autres informations à partir de sources publiques telles que les moteurs de recherche et les médias sociaux.

- Shodan : Pour découvrir des appareils sur l'internet et évaluer leur sécurité.

- DNSdumpster : Pour collecter des informations DNS afin de découvrir des sous-domaines et des adresses IP.

Conclusion pour la phase une

- Dans les tests de pénétration, la reconnaissance permet de dresser une carte complète de la surface d'attaque de la cible et d'identifier les points d'entrée qui peuvent être exploités dans les phases ultérieures de l'attaque.

- Si vous envisagez d'effectuer des tests d'intrusion, la reconnaissance est essentielle pour préparer un engagement réussi et efficace, tout en veillant à respecter l'éthique et les limites légales.

2- SCANNING

- Dans le contexte du piratage éthique ou des tests de pénétration, l'analyse est une étape critique qui vient après la collecte d'informations. L'objectif de l'analyse est d'identifier les systèmes actifs, les ports ouverts, les services en cours d'exécution et toutes les vulnérabilités qui pourraient être exploitées dans le cadre d'une attaque potentielle.

- La phase d'analyse comprend généralement quelques étapes clés :

1. Network Scanning:

- Ping Sweep : Cette technique permet d'identifier les hôtes vivants (dispositifs connectés au réseau) en envoyant des paquets ICMP (Internet Control Message Protocol) à différentes adresses IP. Si un appareil répond, il est considéré comme « vivant ».

- Analyse d'une plage d'adresses IP : Cette technique consiste à analyser une plage définie d'adresses IP afin de déterminer celles qui sont actives.

2. Port Scanning:

- Il s'agit d'identifier les ports ouverts sur un système, qui peuvent être des points d'entrée potentiels. Des outils comme Nmap sont largement utilisés à cette fin.

- Analyse TCP/UDP : Recherche des ports ouverts qui sont à l'écoute des connexions sur les protocoles TCP ou UDP.

- Détection de services : Nmap et d'autres outils peuvent également détecter le service qui fonctionne sur ces ports ouverts, comme HTTP, SSH, FTP, etc.

3. Vulnerability Scanning:

- Après avoir identifié les ports et les services ouverts, l'étape suivante consiste à rechercher les vulnérabilités connues dans les services fonctionnant sur ces ports. Des outils tels que Nessus ou OpenVAS sont utilisés pour trouver les vulnérabilités courantes.

- Ces outils vérifient que le système n'est pas mal configuré, qu'il ne contient pas de logiciels obsolètes et qu'il ne contient pas d'exploits connus

4. Operating System Fingerprinting:

- Processus consistant à déterminer le système d'exploitation (OS) fonctionnant sur un système distant. Cela peut aider les pirates informatiques (ou les pirates éthiques) à déterminer quels types d'exploits pourraient être efficaces.

- Nmap dispose d'une fonction d'empreinte du système d'exploitation qui peut aider à détecter le système d'exploitation en se basant sur le comportement du réseau.

4. Operating System Fingerprinting:

- Processus consistant à déterminer le système d'exploitation (OS) fonctionnant sur un système distant. Cela peut aider les pirates informatiques (ou les pirates éthiques) à déterminer quels types d'exploits pourraient être efficaces.

- Nmap dispose d'une fonction d'empreinte du système d'exploitation qui peut aider à détecter le système d'exploitation en se basant sur le comportement du réseau.

5. Service Version Scanning:

- L'identification des versions des services fonctionnant sur des ports ouverts peut aider à trouver des vulnérabilités spécifiques à cette version.

- Des outils tels que Nmap et WhatWeb peuvent aider à la détection des versions.

6. Web Application Scanning:

- Si la cible est une application web, des outils comme OWASP ZAP ou Burp Suite peuvent rechercher des vulnérabilités telles que l'injection SQL, le Cross-Site Scripting (XSS), etc.

- Les scanners d'applications web tentent souvent de détecter des problèmes tels que des problèmes de validation des entrées ou des mécanismes d'authentification faibles.

Tools Commonly Used in the Scanning Phase:

- Nmap : Pour l'analyse du réseau, l'analyse des ports et l'empreinte du système d'exploitation.
- Nessus : outil d'analyse des vulnérabilités qui identifie les faiblesses potentielles du système.
- OpenVAS : un autre scanner de vulnérabilités très répandu.
- Nikto : Un scanner web pour trouver les vulnérabilités dans les serveurs web.
- Wireshark : Un analyseur de protocole réseau qui peut être utilisé pour capturer des paquets à des fins d'analyse.

Goals of Scanning:

- Identifier la surface d'attaque : La phase d'analyse permet à un pirate éthique d'identifier les endroits où il peut potentiellement attaquer un système.

- Évaluer les vulnérabilités : Aide à déterminer les vulnérabilités du système qui pourraient être exploitées.

- Cartographie de la cible : L'analyse fournit une carte des ports ouverts, des services et des vulnérabilités qui peut être utilisée pour planifier les étapes suivantes de l'attaque (par exemple, l'obtention de l'accès).

Precautions:

- Assurez-vous d'avoir l'autorisation nécessaire pour analyser le système cible. L'analyse non autorisée peut être illégale.
- N'oubliez pas que l'analyse peut déclencher des alarmes sur les systèmes de détection/prévention d'intrusion (IDS/IPS) si elle n'est pas effectuée correctement.

3- Gaining Access:

- L'étape de l'obtention de l'accès est l'une des phases clés du processus de piratage, qui fait généralement partie d'un cycle de vie d'attaque plus large, comme la chaîne d'exécution cybernétique ou d'autres méthodologies de test de pénétration. C'est le moment où l'attaquant réussit à exploiter une vulnérabilité ou une mauvaise configuration pour obtenir un accès non autorisé à un système ou à un réseau.

- Voici un aperçu de ce qui se passe à l'étape de l'obtention de l'accès :

1. Exploiting Vulnerabilities

- Après la reconnaissance (où l'attaquant recueille des informations sur le système cible), il recherche des faiblesses de sécurité qui peuvent être exploitées.
- Ces vulnérabilités peuvent être les suivantes
- des logiciels non corrigés ou des systèmes d'exploitation dont les failles sont connues
- Des mots de passe faibles ou devinables.
- Mauvaise configuration des services de réseau.
- Des attaques d'ingénierie sociale (comme le phishing ou le spear-phishing) pour inciter les utilisateurs à donner leurs informations d'identification ou à exécuter un code malveillant.
- Les vulnérabilités du jour zéro (failles inconnues jusqu'à présent).

2. Techniques for Gaining Access

- Attaques par force brute : Tenter de deviner un mot de passe par essais et erreurs.
- Exploitation des vulnérabilités des logiciels : Tirer parti des failles d'un logiciel ou d'un système (par exemple, débordement de la mémoire tampon, injection SQL).
- Extraction de données d'identification (Credential Dumping) : Utilisation d'outils pour collecter des noms d'utilisateur et des mots de passe (par exemple, à partir d'une base de données ou de la mémoire).
- L'escalade des privilèges : Après l'accès initial, les attaquants peuvent utiliser des exploits locaux pour élever leurs privilèges d'un utilisateur standard à un administrateur.
- Shells Web ou portes dérobées : Après avoir exploité une application ou un serveur web, les pirates peuvent installer un shell web pour conserver l'accès.

3. Establishing Persistence

- Une fois qu'un attaquant a obtenu l'accès, il veut souvent s'assurer qu'il pourra revenir plus tard. Cela peut impliquer

- d'installer des rootkits, des portes dérobées ou des chevaux de Troie

- Ajouter de nouveaux comptes d'utilisateurs avec des privilèges administratifs.

- Modifier les configurations du système pour permettre un accès ultérieur sans être détecté.

4. Exfiltrating Data or Creating a Foothold (Exfiltrer des données ou créer un point d'appui)

- Dans certains cas, l'obtention d'un accès n'est qu'un moyen de passer à d'autres étapes, comme l'escalade des privilèges ou le déplacement latéral dans le réseau. L'objectif final peut être de

- Exfiltrer des données sensibles (par exemple, propriété intellectuelle, informations sur les clients).

- Créer un réseau de zombies ou une autre infrastructure pour de futures attaques.

5. Post-Access Activities

- Une fois l'accès réussi, le pirate peut entreprendre des activités telles que
- Mouvement latéral : Accès à d'autres systèmes au sein du même réseau.
- Collecte de données : Collecte d'informations importantes, telles que les informations d'identification ou la propriété intellectuelle.
- dissimuler ses traces : Effacer les journaux, modifier l'horodatage ou utiliser des outils pour échapper à la détection.

Tools Commonly Used in the Gaining Access Phase:

- Metasploit : Un cadre puissant pour exploiter les vulnérabilités des logiciels.
- Hydra ou John the Ripper : Outils permettant de forcer brutalement les identifiants de connexion.
- Outils d'ingénierie sociale (SET) : Utilisés pour le phishing et d'autres techniques d'ingénierie sociale.
- Cobalt Strike : Outil de post-exploitation et de déplacement latéral.
- Nmap : Souvent utilisé pour la reconnaissance, mais aussi pour l'analyse des vulnérabilités.

Ethical Considerations:

- Cette étape est cruciale pour les hackers éthiques ou les testeurs de pénétration qui évaluent les défenses d'un système. Elle est réalisée avec l'autorisation du propriétaire du système afin d'identifier les faiblesses et d'améliorer la sécurité.

- Pour les pirates malveillants, cette étape conduit à un contrôle non autorisé d'un système cible et est illégale.

4- Maintaining Access:

- Le maintien de l'accès est une phase critique d'une cyberattaque, en particulier dans le contexte d'un piratage ou d'un test de pénétration. Après avoir obtenu l'accès initial à un système, les attaquants s'efforcent souvent de s'assurer qu'ils peuvent continuer à accéder au système ou au réseau même après que la vulnérabilité initiale a été corrigée ou découverte. Cette phase fait appel à diverses techniques pour s'assurer que l'accès peut être rétabli en cas d'interruption.

- Parmi les techniques couramment utilisées pour maintenir l'accès, on peut citer

1. Installing Backdoors:

- Les portes dérobées sont des méthodes secrètes permettant de contourner l'authentification normale et d'accéder à un système. Il peut s'agir d'outils logiciels ou de services modifiés fonctionnant sur le système. Les attaquants peuvent laisser ces portes dérobées ouvertes pour un accès ultérieur.
- Exemples :
- Web shells pour les serveurs web.
- Clés SSH ou configurations de connexion sans mot de passe.
- Logiciels malveillants ou chevaux de Troie personnalisés qui communiquent avec des serveurs de commande et de contrôle externes.

2. Rootkits:

- Les rootkits sont un type de logiciel malveillant conçu pour dissimuler la présence d'autres activités, fichiers ou processus malveillants sur un système. En utilisant des rootkits, les attaquants peuvent rester furtifs et dissimuler leurs activités aux administrateurs système et aux outils de sécurité.

- Les rootkits peuvent modifier le noyau ou les composants au niveau du système afin de fournir un accès continu.

3. **Privilege Escalation:** (L'escalade des privilèges) :

- Les attaquants peuvent élever leurs privilèges une fois qu'ils ont accédé à un système afin d'en accroître le contrôle. Il peut s'agir d'exploiter des vulnérabilités connues pour obtenir des privilèges d'administrateur ou de super-utilisateur.

- Des outils tels que Mimikatz (pour vider les informations d'identification) ou des exploits d'escalade des privilèges locaux sont souvent utilisés à cette fin.

4. L'extraction d'informations d'identification et l'enregistrement de données sur les touches (Keylogging) :

- Les attaquants peuvent extraire les informations d'identification (noms d'utilisateur et mots de passe) du système compromis ou les capturer à l'aide d'enregistreurs de frappe. Une fois qu'ils ont accès aux informations de connexion, ils peuvent accéder à d'autres systèmes ou élever leurs privilèges.

- Des outils tels que Mimikatz ou Windows Credential Editor sont utilisés pour la collecte d'informations d'identification.

5. Tunneling and Proxying:

- Les attaquants peuvent mettre en place des tunnels cryptés (par exemple par le biais de VPN, SSH ou reverse shells) pour acheminer le trafic à travers des systèmes compromis, permettant ainsi une communication non détectée avec des serveurs externes.

- Les VPN, les tunnels SSH ou les serveurs proxy sont fréquemment utilisés pour contourner les pare-feu ou d'autres défenses du réseau.

6. Persistence Mechanisms:

- Les attaquants mettent souvent en place des mécanismes de persistance pour s'assurer que leur accès survit aux redémarrages ou aux mises à jour logicielles. Il peut s'agir d'ajouter des entrées malveillantes aux programmes de démarrage, de créer des tâches planifiées ou de modifier les configurations du système.

- Par exemple, les modifications du registre sous Windows ou les tâches cron sous Linux.

7. Exploitation des relations de confiance :

- Les attaquants peuvent exploiter les relations de confiance entre les systèmes d'un réseau. Par exemple, ils peuvent se déplacer latéralement vers d'autres systèmes au sein du même réseau en s'appuyant sur des informations d'identification ou en exploitant les vulnérabilités des systèmes interconnectés.

8. Use of Remote Access Tools (RATs):

- Les outils d'accès à distance (RAT) permettent aux pirates de contrôler à distance un système compromis. Ces outils permettent souvent l'enregistrement des frappes, la manipulation des fichiers et l'accès à la webcam. Les attaquants peuvent utiliser ces RAT pour interagir avec le système comme s'ils étaient assis devant.

9. Social Engineering:

- Les attaquants peuvent utiliser des techniques d'ingénierie sociale pour s'assurer que l'accès est maintenu, par exemple en manipulant les utilisateurs ou les administrateurs du système pour qu'ils fournissent à leur insu un accès ou des informations d'identification (par exemple, des courriels d'hameçonnage ou de l'ingénierie sociale par téléphone).

10. Web Shells and File Uploads:

- Dans les applications web, les attaquants peuvent télécharger des fichiers malveillants (par exemple, des shells web) pour accéder aux serveurs ou aux environnements web. Ces fichiers permettent aux attaquants d'exécuter des commandes arbitraires et de conserver l'accès.

Examples of Tools Used for Maintaining Access:

- Cobalt Strike :
- Un outil commercial utilisé pour la post-exploitation et le maintien de l'accès. Il fournit une variété d'outils pour aider les attaquants à maintenir la persistance, y compris la possibilité de créer des balises pour une communication secrète.

- Metasploit Framework :
- Metasploit comporte divers modules de post-exploitation qui aident les attaquants à maintenir l'accès en installant des portes dérobées, en recueillant des informations d'identification et en garantissant la persistance.

- Empire :
- Un cadre de post-exploitation qui utilise des agents PowerShell et Python pour maintenir l'accès et exécuter des commandes sur les systèmes compromis.

- Netcat :
- Un simple outil de réseau souvent utilisé par les attaquants pour créer des shells inversés et maintenir l'accès en ouvrant des canaux de communication avec des serveurs externes.

La défense contre le maintien de l'accès :

- Pour empêcher les attaquants de conserver l'accès, les organisations peuvent prendre les mesures suivantes :

- Surveiller le trafic réseau anormal et les connexions non autorisées.
- Apporter régulièrement des correctifs aux systèmes afin de supprimer les vulnérabilités connues.
- Mettre en œuvre des politiques d'authentification multifactorielle (MFA) et de mots de passe forts.
- Réaliser régulièrement des audits et des évaluations de vulnérabilité.
- Utiliser des outils de protection des points d'extrémité pour détecter les comportements malveillants et les logiciels malveillants.
- Limiter les privilèges des utilisateurs au minimum nécessaire à leur rôle.

En prenant ces mesures, les organisations peuvent réduire la probabilité qu'un pirate réussisse à conserver l'accès au fil du temps.

5-Clearing Tracks:(Effacer les traces)

- L'effacement des traces est un élément important du piratage informatique ou de la cyberintrusion, qui permet de couvrir ses activités et d'échapper à la détection. Les pirates informatiques ou les acteurs malveillants utilisent souvent diverses techniques pour supprimer ou dissimuler les preuves de leurs actions. Toutefois, il est important de noter que le piratage ou les activités illégales sont à la fois contraires à l'éthique et illégales. En fait, les professionnels de la cybersécurité s'efforcent de prévenir et de détecter de telles actions afin de protéger les systèmes et les données.

- Si vous vous interrogez sur l'effacement des traces dans le but de les comprendre ou de les prévenir (comme dans le cas du piratage éthique ou des tests de pénétration), voici un aperçu des techniques utilisées pour effacer les traces pendant ou après une intrusion :

1. Log Manipulation (Manipulation du journal)

- Les journaux sont une source d'information essentielle pour la détection des activités de piratage. De nombreux pirates tentent de manipuler ou d'effacer les journaux afin de compliquer la tâche des administrateurs système ou des analystes judiciaires qui souhaitent retracer leurs actions. Ils peuvent
- Supprimer ou modifier les journaux du système (par exemple, les journaux d'événements, les journaux d'authentification ou les journaux du serveur web).
- Désactiver la journalisation pour empêcher l'écriture d'enregistrements.
- Effacer ou modifier les journaux du pare-feu, les journaux d'authentification ou les journaux du système de détection d'intrusion.

2. Clearing Command History

- Dans de nombreux systèmes d'exploitation, les commandes exécutées dans le terminal ou l'invite de commande sont enregistrées dans des fichiers d'historique (par exemple, .bash_history sous Linux, PowerShell history sous Windows). Souvent, les pirates informatiques

- Suppriment ou modifient les fichiers d'historique pour effacer les commandes qui pourraient indiquer des activités malveillantes.

- Configurent le système pour empêcher l'enregistrement de l'historique.

3. Using Anti-Forensic Tools

- Certains attaquants utilisent des outils anti-forensic spécialisés qui sont conçus pour brouiller les pistes en supprimant les traces de leur présence. Ces outils peuvent

- effacer des secteurs du disque pour empêcher les analystes judiciaires de récupérer les données supprimées.

- Masquer les adresses IP ou modifier la géolocalisation, ce qui rend plus difficile le repérage de leur emplacement physique.

- Créer furtivement des portes dérobées qui ne sont pas détectées par les logiciels de sécurité.

4. File and Data Manipulation

- Les pirates peuvent cacher des fichiers malveillants, des logiciels malveillants ou des outils en.. :

- Renommant les fichiers pour qu'ils ressemblent à des fichiers légitimes, ce qui peut les rendre plus difficiles à détecter.

- En chiffrant ou en compressant les fichiers pour rendre difficile leur examen par les outils de police scientifique.

5. Network Traffic Obfuscation (Obfuscation du trafic réseau)

- Utilisation de méthodes telles que les VPN, les proxies ou Tor pour masquer l'origine du trafic réseau et le rendre difficile à remonter jusqu'à l'attaquant.

- L'usurpation d'adresse IP pour falsifier la source des paquets de données, en faisant croire que le trafic provient d'une autre machine.

Fin du cours

- Par ESSOTINA L. Gédéon
- CEO de IPSEC SECURENET
- cisconextipsolutions@gmail.com
- +22891777885